

Silvia Sisinni

silvia.sisinni@polito.it



Module A – Cybersecurity Fundamentals

A5 – Cyber Attacks: Threat Chain, Kill Chain, and Threat Actors



**Politecnico
di Torino**

Department of Control and
Computer Engineering



TORSEC

Computer and Network Security Group



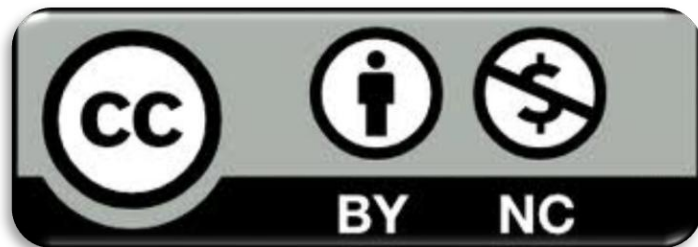
Acknowledgments

This lecture deck *adapts* and *reorganizes* selected teaching material originally developed by Nicolò Maunero (CINI / Cybersecurity National Lab). Portions of the content are reused under the Creative Commons BY-NC license (see license slide). All modifications, additions, re-organization, and any errors are the responsibility of the course instructor.

License & Disclaimer

License Information

This presentation is licensed under the
Creative Commons BY-NC License



To view a copy of the license, visit:

<http://creativecommons.org/licenses/by-nc/3.0/legalcode>

Disclaimer

- We disclaim any warranties or representations as to the accuracy or completeness of this material.
- Materials are provided “as is” without warranty of any kind, either express or implied, including without limitation, warranties of merchantability, fitness for a particular purpose, and non-infringement.
- Under no circumstances shall we be liable for any loss, damage, liability or expense incurred or suffered which is claimed to have resulted from use of this material.
- This material is used and adapted within the course “Cybersecurity and National Defense”.



Learning goals

- Understand **why** cyber-attacks are possible (complexity + cyberspace)
- Define the **Threat Chain**:
 - weakness → vulnerability → exploit → attack
- Describe the **Cyber Kill Chain** and its phases
- Distinguish attacks by **perpetrators** (state / cybercrime / hacktivism)
- Explain the **attacker–defender asymmetry** in cyberspace



Roadmap



- Threat Chain and basic concepts
- Cyber Kill Chain
- Perpetrators
- Cyberspace and asymmetry



Attack objectives

Attacks aim to:

- **Steal:** data (personal / corporate / diplomatic or military), money, intellectual property, identity, credentials and privileged roles inside a system
- **Damage / Disrupt:** services, operations, critical infrastructures, logistics, healthcare, public administration, defense-related systems
- **Manipulate / Control** in a malicious way: alter decisions, falsify data, change system behavior, or control physical processes



Why are cyber-attacks possible?

- The answers can be many and very complex.
- We focus on two fundamental drivers:
 - *System complexity* (Threat Chain)
 - *Nature of the Cyberspace* (asymmetry, jurisdiction, scale)



Threat Chain: complexity domains

- Information systems, regardless of whether they are IT or OT, are mostly *very complex* systems
- Complexity manifests itself in the domain:
 - **Technological**: heterogeneous software stacks, third-party code, OT/IT interconnections
 - **Organizational**: unclear responsibilities, supply-chain dependencies, inconsistent procedures, poor control of the systems
 - **Human**: errors, workarounds to speed up times, social engineering susceptibility

Threat Chain: complexity domains

- **Complexity increases attack surface and misconfiguration probability**
 - A system may be secure in theory and still insecure in practice because its real operational environment is too complex to control perfectly
- **Bruce Schneier**, an American cybersecurity expert, cryptographer, and author known for his work on security systems, privacy, and risk, said:

"Complexity is the worst enemy of security, and our systems are getting more complex all the time"

Bruce Schneier



The Threat Chain

- Complexity $\Rightarrow$ **weak points** across *technology, processes, and people*.
- A **weakness** is a weak point that is **systematic and classifiable** (often recurring patterns)
 - A weakness represents a **systematic flaw** in design, implementation, configuration, or organizational practice.
 - Example: improper input validation, poor access control design, or unclear operational procedures





Weakness



- *A general characteristic referring to systems, or their components, that determines their exposure, i.e., the possibility of losing **Confidentiality**, **Integrity** or **Availability** for their assets.*



Weakness ex.: Improper Input Validation

- Improper input validation is a **general class of design/implementation mistake**. It does not yet describe a specific attack in a specific system.
- The system **does not properly check or sanitize data received from users or external systems** before processing it.
- Imagine a login form where the application expects a username made only of letters and numbers.
- If the program does not validate the input, an attacker could insert something unexpected, for example: ' OR '1'='1 instead of a normal username
- If the system processes that input directly in a database query, it may lead to **SQL injection**, allowing the attacker to bypass authentication.



Weakness ex.: Hard-coded Password

- A password or secret is **written directly inside the program's code** instead of being securely stored or configured.
- Imagine a program that contains something like:

```
if (admin_password == "admin123") {  
    grantAccess();  
}
```

- If someone obtains the software or looks at the code, they may discover that **the password is literally written inside the program**.
- The problem is structural: the system design **assumes that the secret will remain hidden**, even though the software might be inspected, reverse-engineered, or leaked.



Vulnerability



- A particular *weakness*, present in a specific component of a system, that can be *exploited* by an attacker to launch an *attack*.

Deeply analyzed in the lecture:
A7 – “Vulnerabilities and Exploitation”

The Threat Chain

- Some of these details may have weak points (*weaknesses*).
- *Weaknesses* can become *vulnerabilities*.
 - not every weakness becomes a vulnerability in every environment
 - but weaknesses create the conditions from which vulnerabilities emerge

Secure Design
best practices to
avoid weaknesses
in the system

Weaknesses



Vulnerabilities

System hardening,
patching, deploying
compensating
controls, monitoring
and detection tools



Vulnerability ex.: Heartbleed



- **Component involved:** OpenSSL
- **Publicly disclosed:** April 7, 2014
- Heartbleed was a vulnerability in a widely used cryptographic library used to secure HTTPS connections.
- **Mechanism (Heartbeat)** designed to keep a secure connection alive:
 - Client sends data + **declared length** → server echoes it back*
- **Bug:** server did not verify actual message size
- **Impact:** server returns **extra memory contents**
- **Leaked data may include:** passwords, session cookies, private cryptographic keys, user data stored in memory



Vulnerability ex.: Log4Shell



- **Component involved:** Apache Log4j
- **Publicly disclosed:** December 9, 2021
- Log4j is a library used by many applications to **record log messages**.
- Log4j supported a feature called **lookup substitution**, where special expressions inside log messages could automatically retrieve information from external services
- The vulnerability allowed an attacker to insert a **specially crafted string** into data that the system logs.
- When the system wrote that string into the log, the library could be tricked into contacting an attacker-controlled server, **downloading and executing malicious code**.



Vulnerability ex.: EternalBlue



- **Component involved:** Microsoft Windows
- **Publicly disclosed:** April 14, 2017
- This vulnerability affected the Windows file-sharing protocol (SMB).
- In some versions of Windows, the system did not correctly validate certain fields in the network packets.
 - Specially crafted packets could therefore trigger a **memory corruption error**, such as writing data outside the expected memory region
- By sending specially crafted network packets to a vulnerable computer, an attacker could exploit the memory corruption to **inject and execute code on the target machine**, without needing an account or password.
- It was famously used by the **WannaCry** ransomware to spread and infect approximately 200,000 – 300,000 computers across more than 150



Weaknesses vs Vulnerabilities

Weakness

- It is the *class* of security bug
- It represents a *general* problem
 - E.g., **CWE-122**:
Heap-based Buffer Overflow

Vulnerability

- It is the *instance* of that bug in a real system
- It represents a *specific* problem of a *specific* version of a *specific* component
 - E.g., **CVE-2019-6778**:
In QEMU 3.0.0, tcp_emu in slirp/tcp_subr.c has a heap-based buffer overflow



CWE™

➤ CWE - Common Weakness Enumeration

is a community-developed list of common software and hardware security weaknesses.

It serves as a common language, a yardstick for security tools, and a baseline for weakness identification, mitigation, and prevention efforts.

CVE®

➤ CVE: Common Vulnerabilities and Exposures

is a list of entries, each containing an identification number, description, and at least one public reference for publicly known cybersecurity vulnerabilities.



- CWE is a catalog of **recurring design and implementation errors** used mainly by **software engineers** to improve systems security structurally
 - Example: improper input validation
- CVE is catalog of **publicly disclosed vulnerabilities** used mainly by **defenders and security teams** to identify **whether systems are exposed**
 - Example: a vulnerability discovered in a specific software component

✦ **CWE → helps build secure systems**
CVE → helps defend systems when vulnerabilities appear



Vulnerability

- A vulnerability is such **if and only if** it is **exploitable**.
- Exploitability depends on context
 - **Reachability:** Internet-facing / internal / isolated / reachable only through attack chains
 - **Privileges & Preconditions:** authentication required? local access? existing foothold?
 - **User Interaction:** victim must click / open file / enable macro / plug device
 - **Environmental Mitigations:** MFA, segmentation, sandboxing, Endpoint Detection and Response (EDR), memory protections, filtering
 - **Operational Context:** isolated lab system vs Internet-facing production service
- **CVE present $\nRightarrow$ necessarily exploitable in your environment**



Exploit



- *The mean or method of taking advantage of a vulnerability for malicious purposes.*

How to interpret an exploit

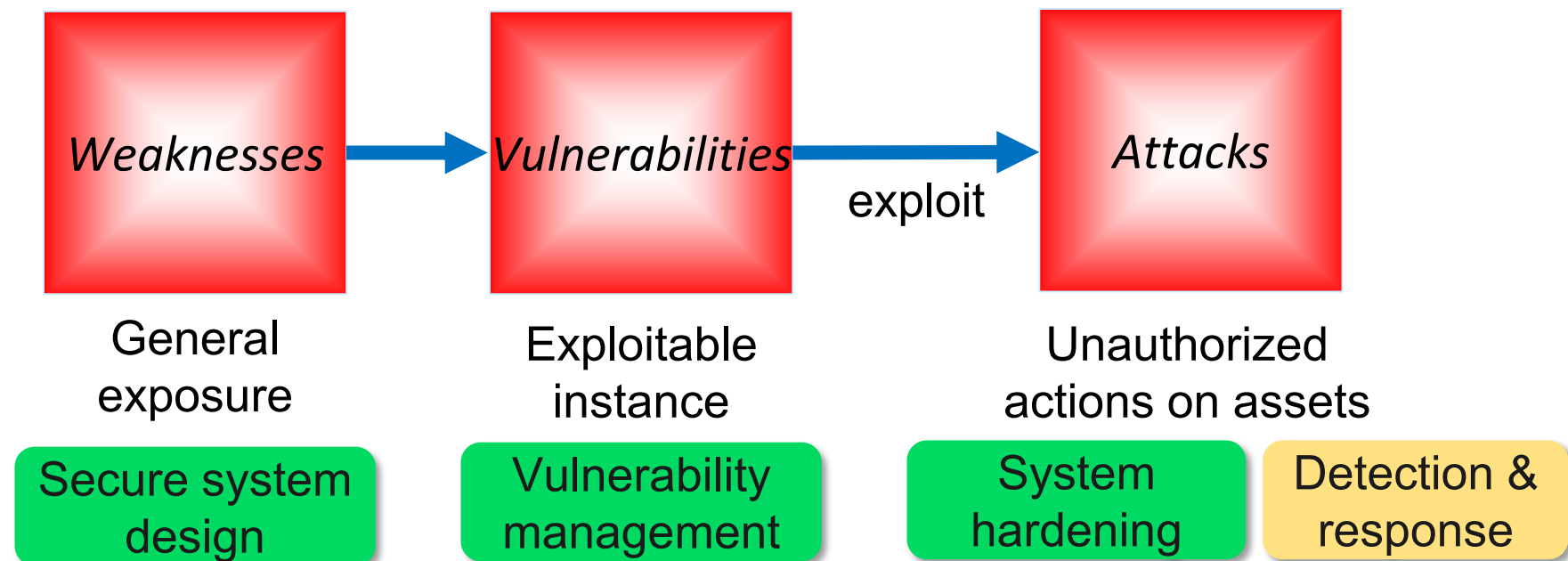
- **Technical artifact:** code, payload, or crafted input that triggers a vulnerability (*e.g., malicious document, crafted network packet*)
- **Operational technique:** the practical way an attacker leverages a vulnerability in a real scenario

Examples

- Malicious document exploiting a parser flaw
- Crafted network packet triggering remote code execution

The Threat Chain (final)

- Some of these details may have weak points (*weaknesses*).
- *Weaknesses* can become *vulnerabilities*.
- *Vulnerabilities* can be exploited to launch *attacks*.





Defender view of the Threat Chain

- **Weakness** → secure design, reviews, architecture
- **Vulnerability** → scanning, asset inventory, patching
- **Exploitability** → hardening, segmentation, least privilege
- **Attack** → detection, containment, recovery



Attack



- A set of unauthorized actions against the *Confidentiality*, *Integrity* or *Availability* of an organization's assets in order to take advantage of them.



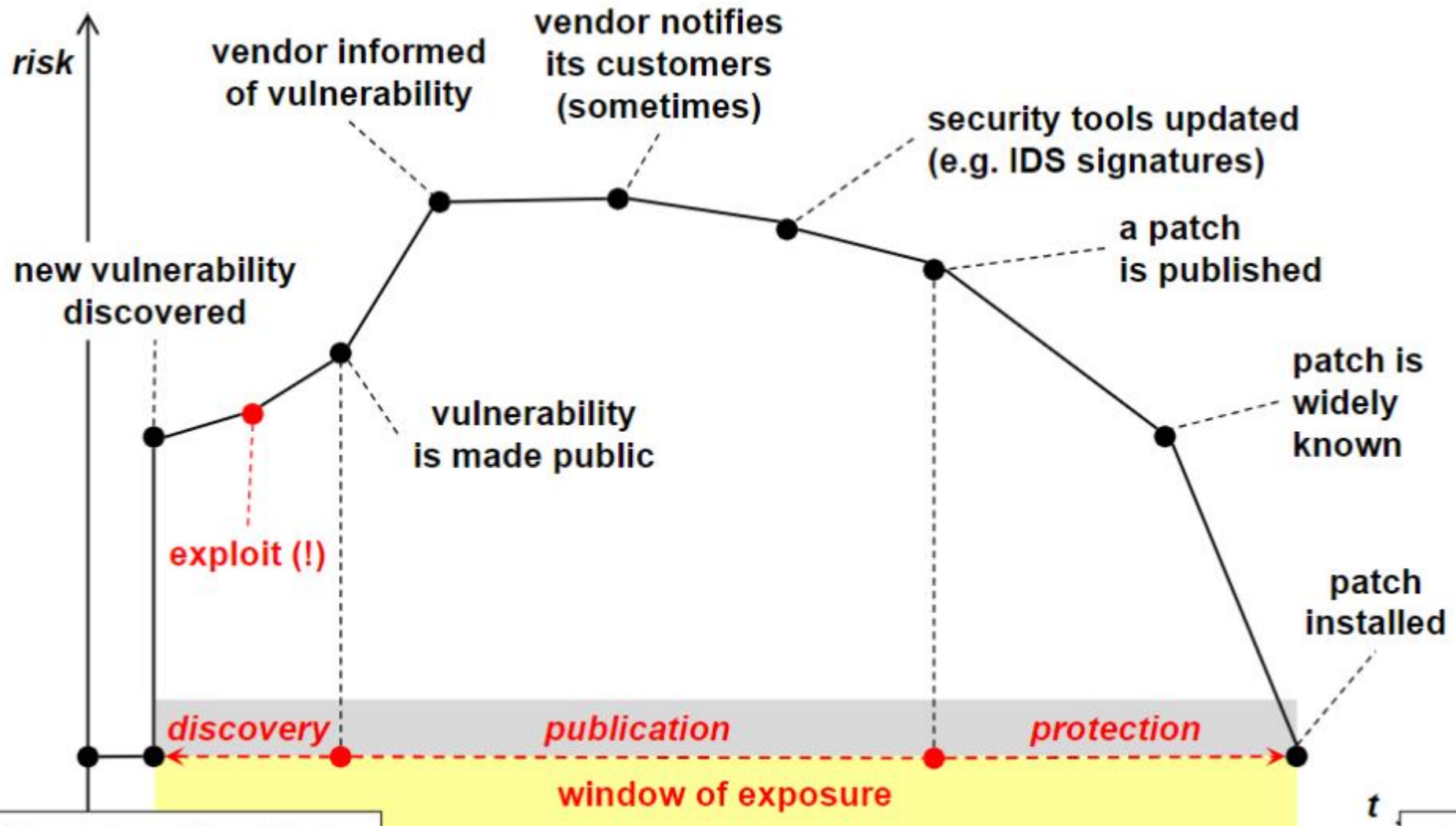
Attack



- Any type of **malicious activity** that attempts to harvest, disrupt, deny, degrade, or destroy information system resources or the information contained therein.

[RFC 2828, Internet Security Glossary, May 2000]

The Window of Exposure





Roadmap



- Threat Chain and basic concepts ✓
- Cyber Kill Chain
- Perpetrators
- Cyberspace and asymmetry



How cyberattacks are performed

- Cyberattacks often follow a structured process known as the **Cyber Kill Chain**, a concept borrowed from military doctrine and adapted to cybersecurity to describe the stages of a malicious operation.

From exposure to execution

- **Threat Chain** → explains *why systems become attackable* (weakness → vulnerability → exploitation → attack)
- **Cyber Kill Chain** → explains *how attacks are executed* (how an attacker progresses from preparation to impact)



From Threat Chain to Kill Chain

Threat Chain

- Why attack opportunities exist
- weakness → vulnerability → exploit → attack

Kill Chain

- How the attacker proceeds
- recon → weaponization → delivery → exploitation → installation → C2 → actions

📌 Threat Chain explains exposure; Kill Chain explains execution



Cyber kill Chain

Typical attack steps:

1. *Reconnaissance*
2. *Weaponization*
3. *Delivery*
4. *Exploitation*
5. *Installation*
6. *Command and Control (C2)*
7. *Actions on Objectives*

- The kill Chain of a cyberattack can take from **minutes** to **years** to complete successfully, depending on:
 - the quality of the target's defenses
 - the preparedness of the target
 - the resource available to the attacker
 - the value of the target



Running Example for the Kill Chain

Scenario

An attacker group wants to **steal proprietary product designs** from a technology company in order to sell them to a competitor.

Target

A mid-size company developing **IoT devices**.

Objective

Gain access to the internal network and obtain **design documents stored in the engineering repository**.



Reconnaissance

- **Goal:** gather information about the target
 - **Technical information:** exposed services and hosts, software versions and vulnerabilities, network ranges and authentication mechanisms
 - **Organizational / human information:** employee identities and email formats, suppliers and partners, public documents and operational details
- **Techniques:**
 - **Passive reconnaissance:** websites, social media, public repositories, domain registration data, leaked credentials
 - **Active reconnaissance:** network scanning and host discovery, service enumeration and banner grabbing
- **Output:**
 - Candidate **entry points**
 - Hypotheses about **attack paths**



Reconnaissance — Example



Scenario: Targeting a technology company to steal product designs.

Passive reconnaissance Collect publicly available information:

- IoT company website → departments and employees
- LinkedIn / GitHub → engineers and technologies used
- Job postings → infrastructure, development tools, used operating systems
- DNS records → email format and subdomains

Active reconnaissance

- Scan internet-facing systems
- Identify web apps and Virtual Private Network (VPN) portals
- Service enumeration / banner grabbing

Output

Chosen entry point: spear-phishing email targeting an engineer



Weaponization

- **Goal:** Prepare the **malicious payload** that will be delivered to the victim.
- **Techniques:**
 - Develop or adapt **malware or malicious scripts**
 - Create **phishing pages or malicious documents**
 - Reuse existing **malware kits or exploit tools**
 - Tailor the payload to the **specific target environment**
- **Output:**
 - A **weaponized artifact** ready for delivery (e.g., malicious document, link, or executable)



Weaponization — Example

Scenario: Targeting an engineer in the technology company.

From Reconnaissance:

- Identify a **specific engineer** working on product development
- Use discovered **corporate email format**
- Study recent projects to craft a **credible message**

Weaponized artifact preparation:

- Prepare a **phishing email** impersonating a collaborator sharing a document
- Attach a **malicious document** disguised as a design file
- Embed **malware that executes when the document is opened**

Result:

→ A **phishing email with a weaponized attachment ready to send**



Delivery

- **Goal:** The attacker transmits the weaponized payload to the target.
- **Techniques:** this can occur through various methods:
 - phishing emails (malicious links or attachments)
 - malicious websites or drive-by downloads
 - direct network exploitation of exposed services
 - Other channels: removable media, compromised supply-chains, messaging platforms, malicious advertisements, ...
- **Output:**
 - The **payload reaches the target environment**
 - First **contact between attacker and victim**



Delivery — Example



Scenario: Targeting an engineer in the technology company.

Action:

- The attacker sends a **spear-phishing email** to the engineer
- The email appears to come from a **trusted collaborator**
 - **Techniques used:** sender spoofing, compromised a legitimate account, domain impersonation

Payload:

- Attachment: *“Updated_Design_Specifications.docx”*
- The document contains **embedded malicious code**

Result:

→ The **weaponized email reaches the victim's inbox**



Exploitation

- **Goal:** The delivered malware exploits a vulnerability or user action, allowing the attacker to execute malicious code on the victim's system.
- **Techniques:**
 - Exploit **software vulnerabilities** (e.g., memory corruption, browser flaws)
 - Abuse **misconfigurations or weak security settings**
 - Use **malicious documents or scripts**
 - Rely on **social engineering** (e.g., convincing the user to perform an action)
- **Output:**
 - **Malicious code execution** on the victim's system
 - First **active compromise of the target**



Exploitation — Example

Scenario: Spear-phishing attack against an engineer.

Trigger

- The engineer **opens the attached document**
- The document prompts the user to **enable macros** (i.e., small programs that can be embedded inside documents to automate tasks, for example in Word or Excel files)

Exploit

- A **malicious macro executes hidden code**
- The code downloads and runs a **malware payload**

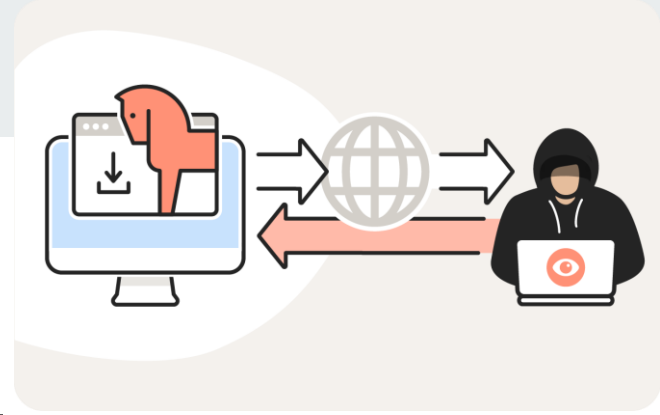
Result

→ The attacker obtains **code execution on the engineer's workstation**



Installation

- **Goal:** the attacker establishes a persistent presence on the targeted system, often installing a backdoor to allow continuous access.
- **Techniques:**
 - Install **malware or backdoor** for remote access
 - Download additional **malicious components**
 - Create **persistence mechanisms** (startup tasks, services)
 - Hide activity using **obfuscation or privilege abuse**
- **Output:**
 - **Persistent access** to the compromised system
 - Platform for **surveillance, lateral movement, or data theft**



Installation — Example

Scenario: Compromised engineer workstation.

Action

- The malicious macro downloads a **Remote Access Trojan (RAT)**
- The malware installs itself on the system

Persistence

- Creates a **startup entry** to run at system boot
- Opens a hidden **remote control channel**

Result

→ The attacker now has **persistent access to the engineer's machine**



Command and Control (C2)

- **Goal:** allow the attacker to **remotely control the compromised system**.
- **Techniques:**
 - Malware establishes **connection to attacker-controlled server**
 - Periodic **beaconing** to receive instructions
 - Integration into **botnets or coordinated infrastructures**
- **Output:**
 - Compromised host becomes a **remotely managed asset**
 - Attacker can **issue commands, update malware, and exfiltrate data**

Command and Control — Example



Scenario: Compromised engineer workstation.

Connection

- The installed malware contacts an **attacker-controlled server**
- Communication occurs over **encrypted HTTPS traffic**

Remote control

- The attacker can now **execute commands on the workstation**, explore the compromised system, collect information, and begin navigating the internal network
- The malware periodically **sends system information**

Result → The attacker gains **interactive control inside the company network**



Actions on Objectives

- **Goal:** The attacker takes actions to achieve their ultimate objectives, whether it's data exfiltration, system damage, creating a botnet, or any other malicious outcome.
- **Techniques:**
 - Data exfiltration (documents, credentials, intellectual property)
 - System manipulation or sabotage
 - Fraud or extortion (e.g., ransomware)
 - Infrastructure abuse (botnets, staging points)
- **Output:**
 - **Confidentiality breach** (data theft)
 - **Integrity compromise** (data manipulation)
 - **Availability disruption** (service interruption)



Actions on Objectives — Example

Scenario: Compromised engineer workstation.

Internal exploration

- The attacker searches the network for the engineering repository **where design documents are stored**
- Uses the engineer's access rights to access internal file servers
 - Because the attacker is operating from a legitimate user's workstation, their activity may initially appear normal within the network

Objective

- Locate **product design documents**
- Compress and **exfiltrate the files** to the attacker's server

Result

→ Theft of **company's proprietary engineering designs**





Where can defenders break the chain?

1. **Reconnaissance** → (*Detect*) exposure management, deception, monitoring
2. **Weaponization** → (*Prevent* / *Detect*) threat intelligence, *attack surface reduction*, sandboxing/detonation
3. **Delivery** → (*Prevent*) filtering, email/web security, user training
4. **Exploitation** → (*Prevent* / *Detect*) patching, hardening, monitoring
5. **Installation** → (*Prevent* / *Detect*) application control, least privilege, monitoring
6. **C2** → (*Prevent* / *Detect*) network detection, egress control (i.e., monitor and restrict outgoing network traffic from an internal system or network to the outside world)
7. **Actions on Objectives** → (*Respond*) incident response, containment, eradication, recovery



Kill Chain: useful, but not universal

- Effective for many intrusion-oriented campaigns
- Less suitable for all attack types and all adversarial behaviours
- Other models answer different questions:
 - **Attack trees** → how can a goal be achieved?
 - We start from an attacker objective and decompose it into alternative ways to achieve that objective
 - **Attack graphs** → what paths can an attacker follow through a system or network?
 - Useful when we want to understand the possible paths an attacker can follow through a system or a network
 - **Attack nets** → how does an attack progress through different states or conditions?
 - Represent how an attack progresses through different states or conditions in a system
- Good analysts use the model as a tool, not as a rigid template



Roadmap



- Threat Chain and basic concepts ✓
- Cyber Kill Chain ✓
- Perpetrators
- Cyberspace and asymmetry

Attacks classification by perpetrators

- According to the perpetrators, attacks are typically classified into:

State-sponsored attacks
(strategic)

Cybercriminal attacks
(profit)

Hacktivist attacks
(ideology)



State-sponsored attacks



- *Cyberattacks are typically conducted by groups, usually referred to as **APT (Advanced Persistent Threat)** that either are part of a government's military or intelligence apparatus (state actors) or are acting on behalf of a government.*
- **Typical goals:**
 - **Espionage:** intelligence collection against governments, defense organizations, diplomats, research centers, or strategic industries
 - **Disruption:** especially against critical services or key infrastructures
 - **Pre-positioning:** gaining and maintaining covert access today in order to create options for future coercion, conflict, or strategic leverage



Advanced Persistent Threat (APT)



*An **Advanced Persistent Threat (APT)** is an adversary that:*

- *has **significant** technical capability, resources, expertise, and operational discipline*
- *combines multiple skills: malware development, exploitation, deception, social engineering*
- *operates **over long periods of time***
- *pursues **strategic objectives***
- *maintains access to **organizations, sectors, or strategic targets***
- *uses **multiple vectors** (cyber + physical + deception)*
- ***adapts** to defensive measures.*

[<https://www.cisa.gov/topics/cyber-threats-and-advisories/advanced-persistent-threats-and-nation-state-actors>]



APT naming and attribution

- Organizations within the cybersecurity community conducting APT research assign names/numbers to APTs upon discovery.
- More than one organization engages in APT research and there may be overlaps among APTs $\Rightarrow$ there can be multiple names for a single APT
 - multiple naming complicates attribution and threat intelligence sharing.
- Treat APT names as “labels for observed activity clusters”, not as ground truth identity.



State-sponsored cyber operations: objectives

National security objectives

- **Espionage:** strategic intelligence collection (government, defense contractors, diplomacy). Goal: information advantage.
- **Disruption / sabotage:** degrade services, weaken capabilities, interfere with systems that are strategically relevant.
- **Pre-positioning:** gain persistent access for future leverage or conflict.

Economic / strategic advantage

- **Intellectual Property (IP) theft:** commercial/industrial espionage to accelerate national industries.



Attacks classification by perpetrators

- According to the perpetrators, attacks are typically classified into:

State-sponsored attacks
(strategic)

Cybercriminal attacks
(profit)

Hacktivist attacks
(ideology)



Cybercriminal attacks

Primary motivation: profit

- Stealing assets or credentials
- Extortion (e.g., ransomware)
- Selling stolen data or access
- Offering criminal services

Cybercrime as an ecosystem

- Specialized roles across the underground market
- Examples: phishing, malware development, credential theft, access brokers, money laundering, ransomware deployment

Scalable criminal operations

- Tools, infrastructure, and data can be **bought or rented**
- Collaboration between actors enables **large-scale campaigns**



Cybercrime: legal definition

- The term *cybercrime* is formalized in the **Council of Europe Budapest Convention (2001)**.

[<https://www.poliziadistato.it/statics/14/convenzione-cybercrime.pdf>]

Purpose of the Convention

It establishes a shared legal baseline for addressing cybercrime:

- **Common definition of offences:** harmonized categories of cybercrime-related offences across countries.
- **International cooperation:** legal mechanisms that enable cross-border investigations.
- **Procedural measures:** rules for evidence preservation, digital investigation, and lawful access



Cybercrime – Legal Definition



General legal definition

*Cybercrime refers to **criminal offences that are committed using computer systems, networks, or digital data, or that target computer systems and data themselves.***

Two broad categories

- **Cyber-enabled crimes:** traditional crime amplified or facilitated by digital systems
 - Examples: online scams, fraud, identity theft, harassment at scale
- **Cyber-dependent crimes:** crime that exists only because digital systems exist
 - Examples: malware, ransomware, botnets, DDoS-for-hire



Budapest Convention: categories of cybercrime

Offenses against CIA of systems/data

- Unauthorized access; unauthorized interception
- Data interference
- System interference

Computer-related offenses

- Computer-related fraud
- computer-related forgery

Content / Intellectual Property (IP)-related offenses

- Child pornography material
- Copyright and related rights offenses



High-impact ransomware incidents

- ***Colonial Pipeline (2021):*** Ransomware attack, orchestrated by the group DarkSide, created significant disruption in fuel supply distribution across several states of the U.S. East Coast. DarkSide, believed to be based in Eastern Europe or Russia, successfully extorted a ransom of \$4.4 million.



High-impact ransomware incidents

- **Colonial Pipeline (2021):** Ransomware attack, orchestrated by the group DarkSide, created significant disruption in fuel supply distribution across several states of the U.S. East Coast. DarkSide, believed to be based in Eastern Europe or Russia, successfully extorted a ransom of \$4.4 million.
- **JBS (2021):** One of the world's largest meat-processing companies, fell victim to a ransomware attack. The attack was carried out by the REvil ransomware group, a Russian-based criminal organization. As a result of the breach, JBS had to suspend operations at 13 of its meat processing plants in the United States. The attackers encrypted some of JBS's information systems, compelling the company to pay an \$11 million ransom in Bitcoin to resolve the situation.



High-impact ransomware incidents

- **Colonial Pipeline (2021):** Ransomware attack, orchestrated by the group DarkSide, created significant disruption in fuel supply distribution across several states of the U.S. East Coast. DarkSide, believed to be based in Eastern Europe or Russia, successfully extorted a ransom of \$4.4 million.
- **JBS (2021):** One of the world's largest meat-processing companies, fell victim to a ransomware attack. The attack was carried out by the REvil ransomware group, a Russian-based criminal organization. As a result of the breach, JBS had to suspend operations at 13 of its meat processing plants in the United States. The attackers encrypted some of JBS's information systems, compelling the company to pay an \$11 million ransom in Bitcoin to resolve the situation.
- **Costa Rica (2022):** The initial entry point into Costa Rica's systems was through the Ministry of Finance. The attackers, the cybercriminal group Conti. This attack extended its reach to several government agencies. The repercussions were severe, leading to significant disruptions in government services such as tax collection, government employee payments, customs, and, ultimately, impacting Costa Rica's foreign trade. It took months to recover.



High-impact ransomware incidents

- **Colonial Pipeline (2021):** Ransomware attack, orchestrated by the group DarkSide, created significant disruption in fuel supply distribution across several states of the U.S. East Coast. DarkSide, believed to be based in Eastern Europe or Russia, successfully extorted a ransom of \$4.4 million.
- **JBS (2021):** One of the world's largest meat-processing companies, fell victim to a ransomware attack. The attack was carried out by the REvil ransomware group, a Russian-based criminal organization. As a result of the breach, JBS had to suspend operations at 13 of its meat processing plants in the United States. The attackers encrypted some of JBS's information systems, compelling the company to pay an \$11 million ransom in Bitcoin to resolve the situation.
- **Costa Rica (2022):** The initial entry point into Costa Rica's systems was through the Ministry of Finance. The attackers, the cybercriminal group Conti. This attack extended its reach to several government agencies. The repercussions were severe, leading to significant disruptions in government services such as tax collection, government employee payments, customs, and, ultimately, impacting Costa Rica's foreign trade. It took months to recover.



Ethics & legality

- Attacking a vulnerable system is considered a *criminal act*
 - the existence of a vulnerability does not create a right to exploit it.

- **Unauthorized access is illegal** even if you “do no damage”.
 - *Analogy*: you don't enter a house just because the door is open.

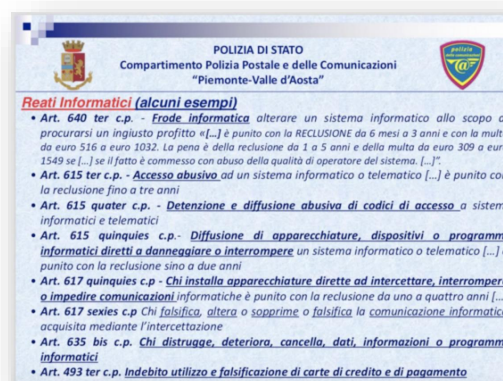
- Security testing requires **explicit authorization** (scope + rules of engagement).



Cybercrimes in Italy

- Cyber crimes are committed by "anyone who, by altering in any way the operation of a computer or telematic system or by intervening without right in any way with data, information or programs contained in or pertaining to a computer or telematic system, procures for himself or others an unfair profit to the detriment of others."

[art. 640 ter c.p.]





Examples



POLIZIA DI STATO
Compartimento Polizia Postale e delle Comunicazioni
"Piemonte-Valle d'Aosta"

Reati Informatici (alcuni esempi)

- **Art. 640 ter c.p. - Frode informatica** alterare un sistema informatico allo scopo di procurarsi un ingiusto profitto «[...] è punito con la RECLUSIONE da 6 mesi a 3 anni e con la multa da euro 516 a euro 1032. La pena è della reclusione da 1 a 5 anni e della multa da euro 309 a euro 1549 se [...] se il fatto è commesso con abuso della qualità di operatore del sistema. [...]».
- **Art. 615 ter c.p. - Accesso abusivo** ad un sistema informatico o telematico [...] è punito con la reclusione fino a tre anni
- **Art. 615 quater c.p. - Detenzione e diffusione abusiva di codici di accesso** a sistemi informatici e telematici
- **Art. 615 quinquies c.p.- Diffusione di apparecchiature, dispositivi o programmi informatici diretti a danneggiare o interrompere** un sistema informatico o telematico [...] è punito con la reclusione sino a due anni
- **Art. 617 quinquies c.p - Chi installa apparecchiature dirette ad intercettare, interrompere o impedire comunicazioni** informatiche è punito con la reclusione da uno a quattro anni [...]
- **Art. 617 sexies c.p** Chi falsifica, altera o sopprime o falsifica la comunicazione informatica acquisita mediante l'intercettazione
- **Art. 635 bis c.p.** Chi distrugge, deteriora, cancella, dati, informazioni o programmi informatici
- **Art. 493 ter c.p.** Indebito utilizzo e falsificazione di carte di credito e di pagamento

Italy: where to find official/national data on incidents

- **ACN (Agenzia per la Cybersicurezza Nazionale):** national strategy, perimeter, coordination, reports.
 - <https://www.acn.gov.it/portale/en/home>
- **CSIRT Italia:** incident trends, advisories, coordinated response information.
 - <https://www.acn.gov.it/portale/en/csirt-italia>
- **CLUSIT Report (Italy):** annual snapshot (methodology-dependent; useful for trends).
 - <https://clusit.it/rapporto-clusit/>





Cybercrime as an ecosystem

- Specialized roles: malware developers, spammers, phishers, access brokers, affiliates, money mules
- Services are traded in underground markets and forums
- Criminal operations scale because not every actor needs every skill
- Profit comes from cooperation, specialization, and monetization chains



Cybercrime cost: direct vs indirect losses

Direct losses

- Fraud, theft, extortion
- Theft of personal/financial data
- Intellectual property theft

Indirect losses

- Operational downtime and disruption
- Incident response
- Forensics investigation
- Recovery/restoration and hardening
- Productivity loss
- Reputational damage

✦ For critical services, indirect losses (downtime + recovery) often dominate.



The Global Economic Cost of Cybercrime

Key Empirical Estimates, Center for Strategic and International Studies (CSIS) Reports:

- **2014** - Estimated global cost: **~USD 445 billion**
(Net Losses: Estimating the Global Cost of Cybercrime)
- **2018** - Estimated global cost: **~USD 600 billion**
(The Economic Impact of Cybercrime)
- **2020** - Estimated global cost: **~USD 1 trillion**
(The Hidden Costs of Cybercrime)

The Global Economic Cost of Cybercrime

Cybercrime To Cost The World \$12.2 Trillion Annually By 2031



Cyber Rica is the world's third largest economy [Press Release](#)

– [David Braue](#), Editor-at-Large

Melbourne, Australia – May 28, 2025



Cybercrime is predicted to cost the world [\\$10.5 trillion USD in 2025](#), according to Cybersecurity Ventures. If it were measured as a country, then cybercrime would be the world's third largest economy after the U.S. and China. This represents the greatest transfer of economic wealth in history, risks the incentives for innovation and investment, is exponentially larger than the damage inflicted from natural disasters in a year, and will be more profitable than the global trade of all major illegal drugs combined.

Global cybercriminal activity has grown so large that, after years of rapid expansion, Cybersecurity Ventures believes the sector's sheer economic weight will see growth plateau at [2.5 percent annually](#) through [2031](#), at which point cybercrime will cost the world \$12.2 trillion annually.

Attacks classification by perpetrators

- According to the perpetrators, attacks are typically classified into:

State-sponsored attacks
(strategic)

Cybercriminal attacks
(profit)

Hacktivist attacks
(ideology)



Hacktivism



- *The practice of breaking into or disrupting computer systems for **politically** or **socially motivated reasons**, typically outside any government affiliation.*



Hacktivist operations: typical patterns

- Self-presentation as activists, so known as *hacktivists*
 - Actors portray themselves as defending a cause, grievance, or political narrative. Visibility is often part of the objective.
- Actors can be **individuals** or **loosely coordinated collectives**
 - Hacktivism may involve single hackers, but more often loosely coordinated groups rather than rigid organizations.
- Targets include **government**, **media**, **companies**, and sometimes **critical services**, chosen for their public or political significance.
- Goals often include **visibility**, **narrative influence**, and **pressure through disruption**, rather than long-term covert access or financial gain.



Hacktivist tactics: visibility over persistence

- **Operational logic:** Hacktivist operations typically prioritize visibility over persistence
- **Common actions:** website defacement, DDoS attacks, data leaks, account hijacking, doxing (i.e., public disclosure of private or identifying information about an individual without their consent)
- **Communicative disruption:** these actions are designed to create public embarrassment, media attention, and symbolic disruption
- **Typical impact:** effects are often reputational and political, rather than financial or strategic



Classification of defenses

Based on actors and purpose, defenses are typically classified into:

Cyber-investigation (Law enforcement)

Goal: attribution for prosecution and disruption of criminal networks.

Activities: digital forensics, evidence collection, takedowns, cooperation with international partners.

Cyber-intelligence (Intelligence community)

Goal: situational awareness on actors, capabilities, intentions, and possible threats.

Activities: collection (passive/active), analysis, threat assessments.

Cyber-defence (Military / national defense)

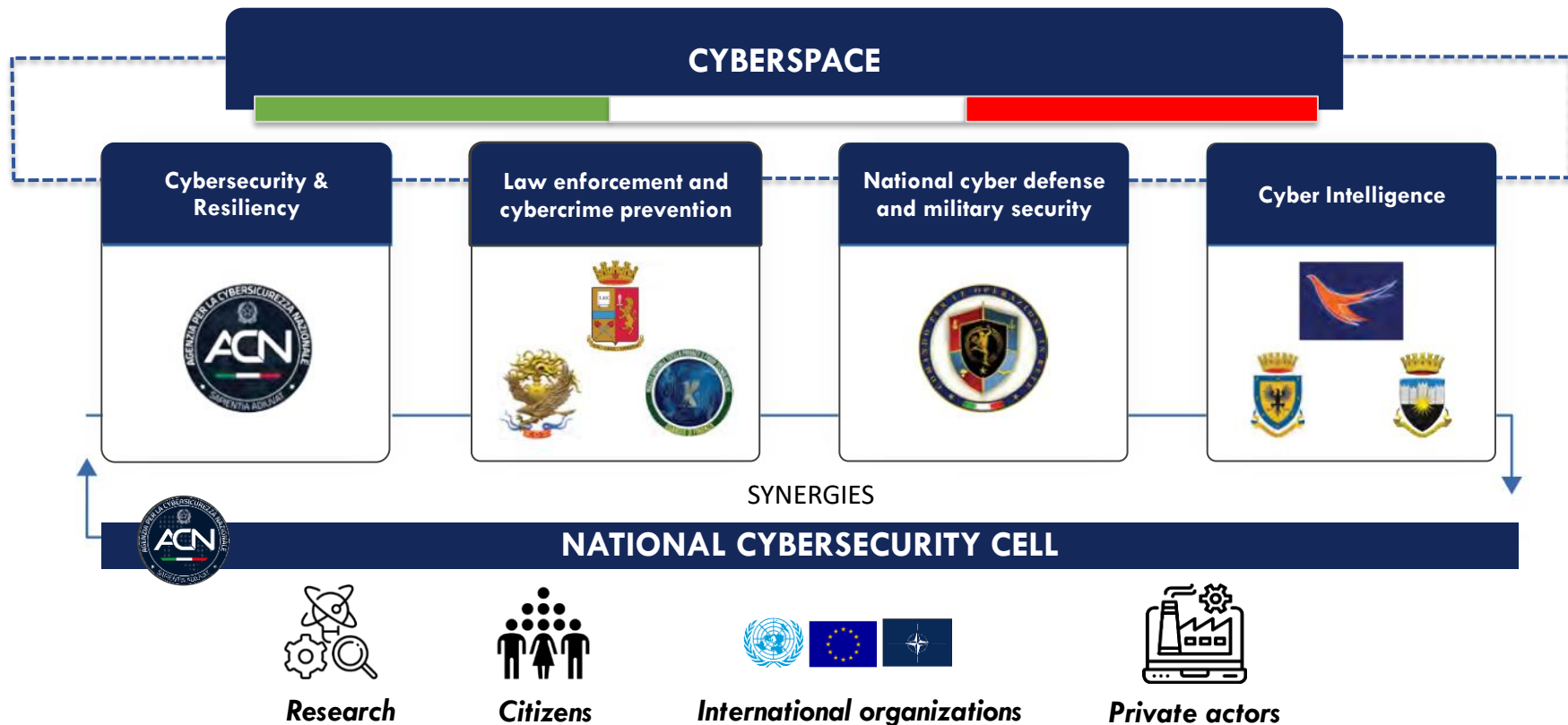
Goal: protect national missions; ensure resilience, support response; deterrence and active defense.

Activities: resilience, protection, response, and (where mandated) proactive operations.

National Cyber Architecture: functional pillars

National Cyber Architecture

Bodies in defense of the National Cyber Architecture





Italian National Cyber Architecture: key pillars

- **Cybersecurity & resilience -- ACN:** national policy, national coordination for cyber protection, resilience, prevention, preparedness, and implementation of national strategy
- **Law enforcement -- Polizia Postale / CNAIPIC:** investigation, collection of digital evidence, support to judicial proceedings, disruption of criminal activity
- **National cyber defence -- Ministry of Defence / COR:** military security, conducting operations in the cyber domain, secure technical-operational management of Defence ICT
- **Cyber intelligence – DIS, AISE, AISI:** threat assessment, actors, capabilities, intent



National cyber architecture: coordination

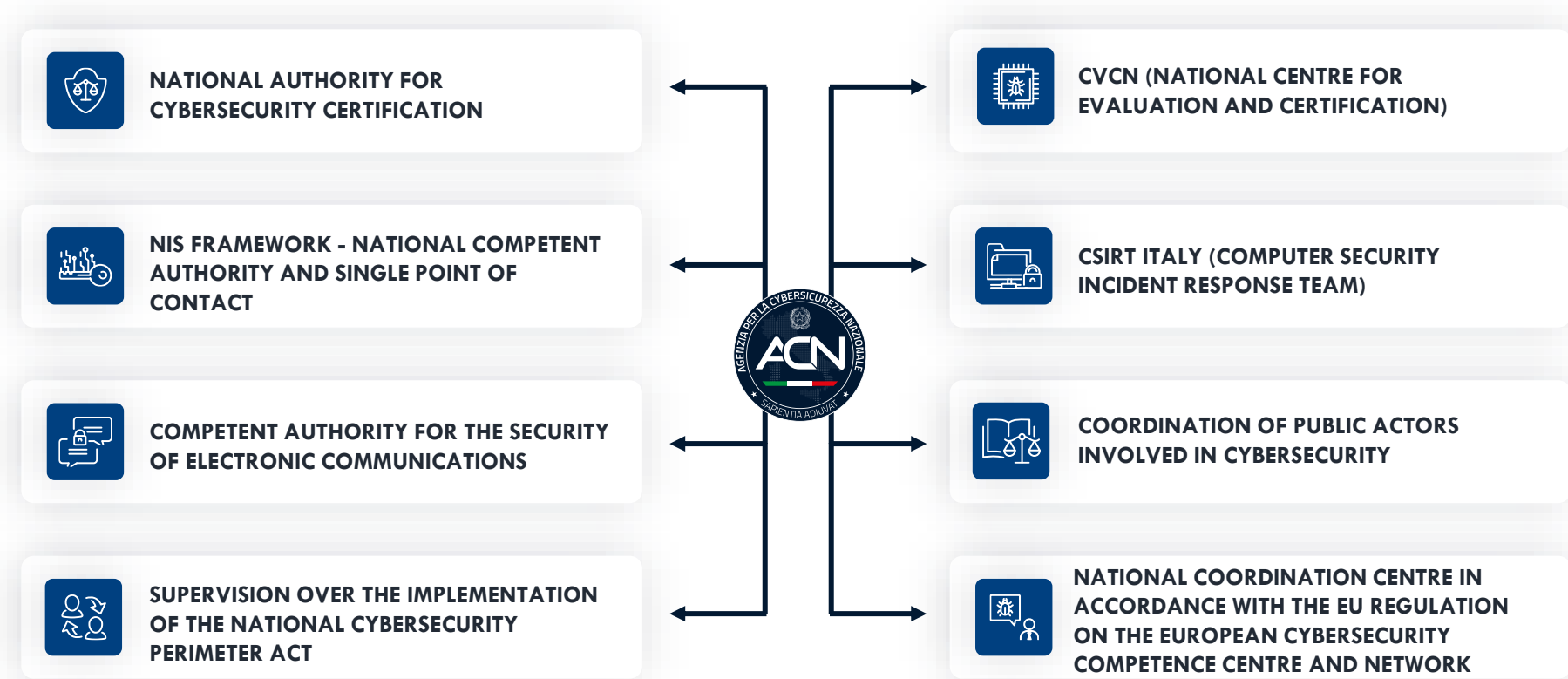
- Pillars are distinct, but interdependent
- Major cyber incidents cut across multiple functions
- **Response requires coordination** among resilience, law enforcement, defence, and intelligence
- **Political-strategic alignment** is supported by the **Comitato Interministeriale per la Cybersicurezza (CIC)**
- National cybersecurity involves a broader **cybersecurity ecosystem**: research, citizens, private actors, EU/NATO, international partners



ACN (Agenzia per la Cybersicurezza Nazionale)

National Cyber Architecture

National Authority for Cybersecurity





Roadmap



- Threat Chain and basic concepts ✓
- Cyber Kill Chain ✓
- Perpetrators ✓
- Cyberspace and asymmetry



Why are cyber-attacks possible?

- The answers can be many and very complex.
- We focus on two fundamental drivers:
 - *System complexity* (Threat Chain)
 - *Nature of the Cyberspace* (asymmetry, jurisdiction, scale, anonymity, reuse of tools)



Cyberspace: no man's land...

- Cyberspace is often considered “no man's land” because of:
 - **Absence of clear boundaries:** a digital operation can move through devices, networks, cloud services, registrars, hosting providers, and communication channels distributed across many countries ⇒ the “location” of an attack is often ambiguous.
 - **Lack of clear transnational jurisdiction:** a victim may be in one country, the attacker in another, the infrastructure in a third, and the financial flows in several others. This complicates attribution, evidence gathering, and legal cooperation.
 - **Social paradigms are radically different:** the Internet removes the need for physical proximity, reduces the cost of reaching victims, accelerates operations, and makes large-scale targeting feasible in ways that were much harder in the physical world.



Cyberspace as an opportunity structure

- **Global reach** at near-zero marginal cost
- **Scalability of attacks** (automation, botnets, reuse of tools and infrastructure)
- **Low barriers to entry** (commodity malware, exploit kit markets, crime-as-a-service)
- **Operational anonymity** and obfuscation
- **Rapid displacement** and adaptation



Consequence: attacker–defender asymmetry

- Great asymmetry between attackers and defenders (*in favor of the attackers*):
 - attackers need **one viable path**; defenders must cover **many** assets, many interfaces, many users, and many configurations;
 - attackers choose **timing and target**; defenders are **always-on**, they cannot choose to defend only on convenient days or in convenient places;
 - defenders face attribution challenges, legal constraints, internal escalation paths, and coordination requirements; these constraints often slow down reaction compared with an attacker who can act opportunistically and without accountability



The defender's dilemma (asymmetry in practice)

Defender

- must cover **all attack surfaces**
- mitigates **known vulnerabilities**
- operates continuously (**always-on**)
- constrained by **rules and accountability**
- needs **coordination** across teams
- **training** often requires **full infrastructure** access

Attacker

- targets the **weakest point**
- searches for **unknown vulnerabilities**
- chooses **time and place**
- **opportunistic and adaptive**
- can **act alone** or **outsource capabilities**
- **training** requires **minimal infrastructure**



Information sharing: asymmetric incentives

- **Attackers often benefit from sharing**
 - tools, malware, access services, scripts
 - reuse reduces marginal cost and enables scaling
- **Defenders often face disincentives to share**
 - reputational damage, liability, exposure of weaknesses
 - regulatory or disclosure concerns
- **Structured sharing mechanisms are therefore needed**
 - coordinated vulnerability disclosure
 - CSIRT and ISAC information-sharing channels
 - **shared Tactics, Techniques, and Procedures (TTP) / Indicators of Compromise (IOC) formats** for actionable intelligence, designed specifically to make actionable information exchange easier across organizations.



From silence to structured sharing

Shareable objects

- **IOCs (Indicators of Compromise):** malicious IPs, domains, file hashes that signal an intrusion, artifacts of attacks
- **TTPs (Tactics, Techniques, Procedures):** attacker behaviours and operational methods observed during an attack
- **YARA rules:** pattern-matching rules used to detect malware
- **Incident patterns:** recurring attack infrastructures or campaign characteristics



From silence to structured sharing

Trusted channels

- CSIRTs (Computer Security Incident Response Teams)
- ISACs (Information Sharing and Analysis Centers)
- Sectoral or national security communities

Formats and platforms for sharing

- **STIX** (Structured Threat Information eXpression): machine-readable threat intelligence format
- **IODEF** (Incident Object Description Exchange Format): incident reporting format
- **MISP** (Malware Information Sharing Platform): collaborative threat-intelligence platform



Reversing Miranda Rights

From (criminal law logic)

- **You have the right to remain silent.** Anything you say can and will be used against you in a court of law.

To (cybersecurity logic)

- You have the right to remain silent. If you give up that right, **NOTHING** you say can and will be used against you in a court of law. Conversely, any information you would keep secret or hidden may be used against you if a damage were to be.



Consequences: economic asymmetry and **Crime-as-a-Service**

- **Attack infrastructure has fixed costs:** tooling, malware, botnets, phishing kits
- **Each additional victim adds low marginal cost:** automation and reuse enable rapid scaling
- **Defenders face the opposite logic:** each asset, control, or monitoring requirement adds cost
- **Cybercrime evolves toward Crime-as-a-Service (CaaS):** access, infrastructure, malware, and distribution can be rented or outsourced
- **Result:** attacks scale with **less effort, lower expertise, and relatively lower risk**